The Report II

1. Kịch bản

- Bạn làm việc trong 1 nhóm SOC và cần tìm hiểu thêm về báo cáo do MITRE phát hành để cải tiến SOC của mình.
- Report Link: https://www.mitre.org/sites/default/files/publications/11-strategies-of-a-world-class-cybersecurity-operations-center.pdf

Nội dung Report

PHẦN MỞ ĐẦU – TƯ DUY XUYÊN SUỐT TÀI LIỆU

Tài liệu này không nói về:

- Dùng SIEM nào
- Dùng EDR nào
- Viết rule ra sao

👉 Tài liệu trả lời câu hỏi lớn hơn:

> "Làm thế nào để một SOC THỰC SỰ bảo vệ được tổ chức trước tấn công hiện đại?"

Toàn bộ 11 chiến lược xoay quanh 3 trụ:

- **Con người**
- **Quy trình**
- **Khả năng phát hiện & phản ứng thực tế**

SOC được đánh giá **không phải bằng số alert**, mà bằng:

- Phát hiện sớm đến mức nào
- Giảm thiệt hại ra sao
- Học được gì sau mỗi incident

STRATEGY 1

KNOW WHAT YOU ARE PROTECTING AND WHY

(Hiểu rõ bạn đang bảo vệ cái gì – và vì sao nó quan trọng)

Nội dung cốt lõi

SOC **không thể phát hiện và ưu tiên đúng** nếu không hiểu bối cảnh tổ chức.

SOC analyst cần hiểu:

1. **Business context**
    - Tổ chức sống nhờ hệ thống nào?
    - Dịch vụ nào dừng là gây thiệt hại nghiêm trọng?
2. **Critical assets**
    - Server, database, cloud service nào là “crown jewels”?
    - Không phải hệ thống nào cũng quan trọng như nhau.
3. **Data sensitivity & compliance**
    - Dữ liệu cá nhân, tài chính, y tế
    - Incident nào có nghĩa vụ pháp lý phải báo cáo?
4. **Environment**
    - On-prem, cloud, hybrid
    - Kiến trúc ảnh hưởng trực tiếp đến cách attacker xâm nhập.
5. **User & behavior**
    - Ai là admin?
    - Hành vi nào là bình thường, hành vi nào là bất thường?
6. **Threat landscape**
    - Ai có động cơ tấn công?
    - Mục tiêu của họ là dữ liệu, tiền hay phá hoại?

Ý nghĩa với SOC analyst

👉 Alert **chỉ có giá trị khi đặt trong ngữ cảnh**

👉 SOC analyst không hỏi "có alert không?", mà hỏi **"alert này có ảnh hưởng gì?"**

STRATEGY 2

GIVE THE SOC THE AUTHORITY TO DO ITS JOB

(SOC phải có thẩm quyền hành động)

Vấn đề thực tế

Nhiều SOC:

- Phát hiện malware
- Phát hiện account compromise

  Nhưng **không được phép can thiệp**, phải chờ phê duyệt.

→ Tấn công lan rộng → SOC thất bại dù phát hiện đúng.

Nội dung cốt lõi

SOC cần:

- Quyền truy cập log, endpoint, network
- Quyền cô lập máy, khóa account
- Quyền kích hoạt Incident Response ngay khi cần

Ý nghĩa

👉 SOC **không chỉ giám sát**, mà **thực sự bảo vệ hệ thống**

STRATEGY 3

BUILD A SOC STRUCTURE THAT MATCHES ORGANIZATIONAL NEEDS

(SOC phải phù hợp tổ chức)

Nội dung cốt lõi

Không tồn tại “SOC chuẩn cho mọi nơi”.

SOC phải được thiết kế dựa trên:

- Quy mô tổ chức
- Ngành nghề
- Mức rủi ro
- Ngân sách

Có thể là:

- SOC nội bộ
- SOC thuê ngoài
- SOC kết hợp
- Tiered hoặc tierless
- 24/7 hoặc theo giờ hành chính

Ý nghĩa

👉 SOC tốt là SOC **phù hợp thực tế**, không phải SOC “đẹp trên slide”

STRATEGY 4

HIRE AND GROW QUALITY STAFF

(Con người là yếu tố quyết định)

Nội dung cốt lõi

SOC không phải dây chuyền xử lý alert.

SOC analyst cần:

- Tư duy phân tích

- Hiểu hệ thống
- Hiểu attacker

Tổ chức phải:

- Tuyển đúng người
- Đào tạo liên tục
- Có lộ trình phát triển
- Giảm burnout

Ý nghĩa

👉 Tool có thể mua, **analyst giỏi thì không**

STRATEGY 5

PRIORITIZE INCIDENT RESPONSE

(Incident Response là trung tâm)

Nội dung cốt lõi

SOC tồn tại **để xử lý incident**, không phải chỉ để phát hiện.

SOC cần:

- IR plan
- Playbook rõ ràng
- Escalation path
- Phân vai trách nhiệm

IR lifecycle:

1. Chuẩn bị
2. Phát hiện
3. Phân tích

4. Cô lập
5. Loại bỏ
6. Khôi phục
7. Rút kinh nghiệm

Ý nghĩa

👉 Khi incident xảy ra, SOC **phản ứng có tổ chức, không hoảng loạn**

STRATEGY 6

ILLUMINATE ADVERSARIES WITH CYBER THREAT INTELLIGENCE

(Hiểu đối thủ bằng CTI)

Nội dung cốt lõi

CTI không chỉ là danh sách IP/domain xấu.

CTI giúp:

- Hiểu attacker là ai
- Họ dùng kỹ thuật gì
- Họ thường nhắm vào đâu

SOC dùng CTI để:

- Ưu tiên alert
- Tuning detection
- Threat hunting
- Chủ động phòng thủ

Ý nghĩa

👉 SOC analyst hiểu **TTP**, không chỉ IOC

STRATEGY 7

SELECT AND COLLECT THE RIGHT DATA

(Thu thập đúng dữ liệu)

Nội dung cốt lõi

Không phải càng nhiều log càng tốt.

SOC cần dữ liệu:

- Có giá trị điều tra
- Phù hợp mối đe dọa

Ưu tiên:

- Endpoint
- Identity & authentication
- Cloud logs

Ý nghĩa

👉 SOC analyst có **evidence**, không phải đoán mò

STRATEGY 8

LEVERAGE TOOLS TO SUPPORT ANALYST WORKFLOWS

(Tool phục vụ analyst)

Nội dung cốt lõi

Tool là phương tiện, không phải mục tiêu.

SIEM / EDR / SOAR phải:

- Kết nối tốt

- Giảm thao tác thủ công
- Hỗ trợ điều tra & phản ứng

Ý nghĩa

👉 Analyst dùng não nhiều hơn chuột

STRATEGY 9

COMMUNICATE CLEARLY, COLLABORATE OFTEN

(Giao tiếp & phối hợp)

Nội dung cốt lõi

SOC không thể làm việc một mình.

Cần phối hợp với:

- IT
- Cloud
- Management
- Đội khác

Báo cáo phải:

- Rõ ràng
- Đúng đối tượng
- Có hành động cụ thể

Ý nghĩa

👉 SOC là **đối tác bảo vệ tổ chức**, không phải “bộ phận báo lỗi”

STRATEGY 10

MEASURE PERFORMANCE TO IMPROVE PERFORMANCE

(Không đo → không cải thiện)

Nội dung cốt lõi

SOC phải đo:

- MTTD: phát hiện nhanh hay chậm
- MTTR: xử lý nhanh hay chậm
- False Positive: alert có chất lượng không
- Coverage: có phát hiện đủ kỹ thuật tấn công không

Ý nghĩa

👉 Đo để biết **SOC yếu ở đâu và cải thiện chỗ nào**

STRATEGY 11

EXPAND SOC FUNCTIONALITY WHEN READY

(Mở rộng khi nền tảng đã vững)

Nội dung cốt lõi

Chỉ mở rộng khi:

- Detection tốt
- IR ổn định
- SOC vận hành trơn tru

Mở rộng sang:

- Threat hunting
- Malware analysis
- DFIR

- Purple team

Ý nghĩa

👉 SOC từ **bị động → chủ động**

KẾT LUẬN CUỐI CÙNG

📌 Tài liệu này dạy **tư duy SOC đúng**, không dạy tool

📌 SOC đẳng cấp thế giới là SOC:

- Hiểu tổ chức
- Hiểu attacker
- Có quyền hành động
- Có con người giỏi
- Có dữ liệu đúng
- Có khả năng học sau mỗi incident

2. Write-up

1. Submit the name of the units/teams (in short form) that are responsible for maintaining network and other IT equipment, incident detection and response, and security compliance and risk measurement (Format: Team1, Team2, Team3)

- NOC (hoặc trung tâm vận hành IT): vận hành và bảo trì mạng và các thiết bị CNTT khác
- SOC: phát hiện và xử lý sự cố
- ISCM (Information Security Continuous Monitoring): tuân thủ an ninh và đo lường risk

2. After investigation, what are the 4 suggested 'Response Options' mentioned in Basic SOC Workflow? (Format: Option1, Option2, Option3, Option4)

- Block Activity
- Deactivate Account

- Continue Watching
- Refer to Outside Party

3. What is the name of a military strategy used in SOCs to achieve a high level of situational awareness? (Format: Strategy Name)

- OODA Loop: là chu kì quyết định nhận thức tự củng cố
  - O - observer: quan sát
  - O - orient: định hướng
  - D - decide: quyết định
  - A - act: hành động

4. What is the name of the suggested organisational model if the constituency size is between 1000 to 10,000 employees (Format: Organisational Model Name)

- Distributed SOC: doanh nghiệp/trường học vừa và nhỏ, chính quyền địa phương

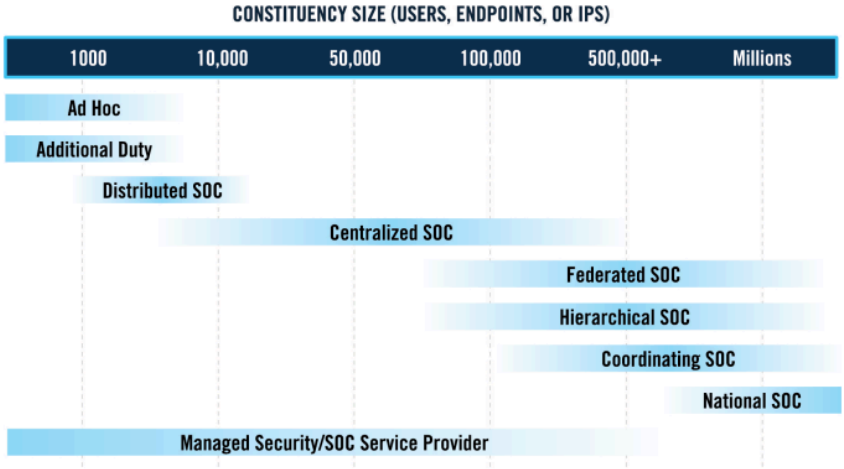

Figure 6. SOC Organizational Model Versus Constituency Size

5. In a Large Centralised SOC, who is responsible for generating SOC metrics, maintaining situational awareness, and conducting internal/external trainings? (Format: Role Name)

- SOC Operations Lead

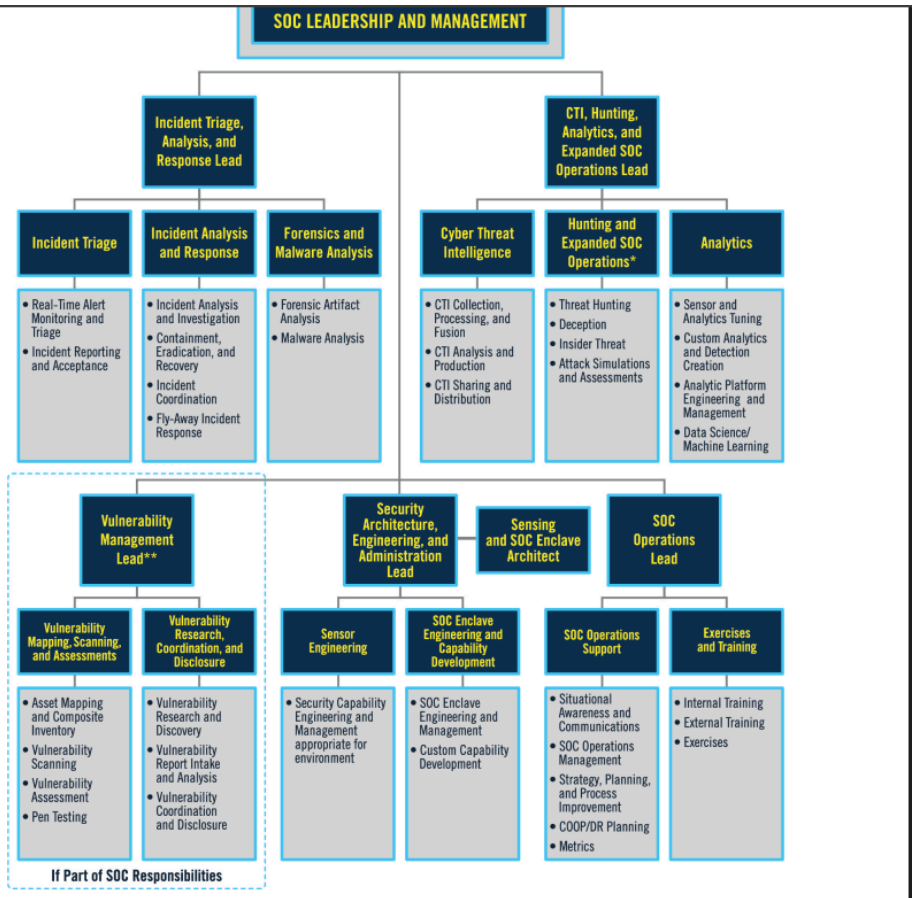

Figure 9. Large SOC

6. In Coordinating & National SOCs model what are the 2 functions mentioned as Optional Capability under Expanded SOC Operations Category? (Format: Function1, Function2)

- Deception, Insider Threat

Data Science and Machine Learning	n	o	b	a	o
Expanded SOC Operations					
Attack Simulation and Assessments	n	o	b	a	a
Deception	n	n	o	o	o
Insider Threat	n	n	o	b	o

74 | 11 Strategies of a World-Class Cybersecurity Operations Center

	Security As Additional Duty	Distributed SOCs Small/Young Centralized & Federated SOCs	Large/Mature Centralized & Federated SOCs	Hierarchical SOCs	Coordinating & National SOCs
Vulnerability Management (if performed by the SOC)					

7. What are the two virtual console technologies (in short form) mentioned to support Virtual SOC/ Remote Work scenarios during pandemics? (Format: Technology1, Technology2)

- iLO, iDRAC
  - iLO: công nghệ quản lý server từ xa của HPE
  - iDRAC: công nghệ tương đương nhưng của Dell

8. What is the name of the model used to distribute work load of SOC 24/7 across different timezones to eliminate working at night hours? (Format: Model Name)

- Follow-the-sun operating models
  - Họp vào thời điểm giao cao
    - Ca trước ở lại, ca sau đến sớm hơn
    - Truyền đạt in4 trực tiếp và không cần làm đêm
  - Ghi hình/ghi âm để xem lại
    - Xem lại khi rảnh, in4 nhất quán

    - Không truyền đạt được trực tiếp

9. Submit the priorities(Low, Medium, High) assigned to Phishing, Insider Threat and Pre-incident Port Scanning activities respectively as per the Incident Prioritization mentioned in the document (Format: Priority1, Priority2, Priority3)

- Medium, High, Low

Incident/Event	Priority Level	Response or Action
Most port Scanning activity (pre-incident)	Low	Ignore most of these. Block or incorporate into detection if scans are tied to other reconnaissance, a known bad reputation, or there are multiple events from the source.
Malware infection	Medium	Remediate any malware infections as quickly as possible before they progress. Scan the rest of the constituency or enclave for associated indicators (e.g., SHA256 hashes).
Denial of service	Low-Medium, depending on duration	Configure affected externally facing services/systems e.g., web servers) to protect against DoS requests (e.g., HTTP and/or synchronized (SYN) flood). Coordinate with Internet Service Provider (ISP) to block/reroute the activity.
Unauthorized access	High	Detect, monitor, and investigate all unauthorized access attempts; prioritize mission-critical or sensitive data. Remediate through rebuilding accounts, systems, etc. as determined.
Insider threat	High	Identify associated privileged accounts for all domains, servers, apps, and critical devices. Ensure monitoring is enabled. Shut down access and/or coordinate with authorities where appropriate.
Web attacks (XSS, SQL ingestion, Cross-Site Request Forgery (CSRF), etc.)	High	Follow unauthorized access and/or malware response, depending on circumstance. Check web services, application, and database logs for extent of incident.
Phishing	Medium	Follow malware infection response or action. Check e-mail and other indicators for other recipients and attacks.

10. Mention the name of the Open source Operating system mentioned, that can help in mobile incident investigations (Format: OS Name)

- Santoku: mobile forensics, malware vaf bảo mật → tạo ảnh và phân tích thiết bị, dịch ngược và phân tích malware

11. Before choosing a CTI tool, the document suggests tool support for 2 open threat intelligence standards (short forms), what are they? (Format: Standard1, Standard2)

- STIX, TAXII

12. Name the Data Source which consumes the highest volume (typically TB's/day)? (Format: Data Source Name)

- PCAP

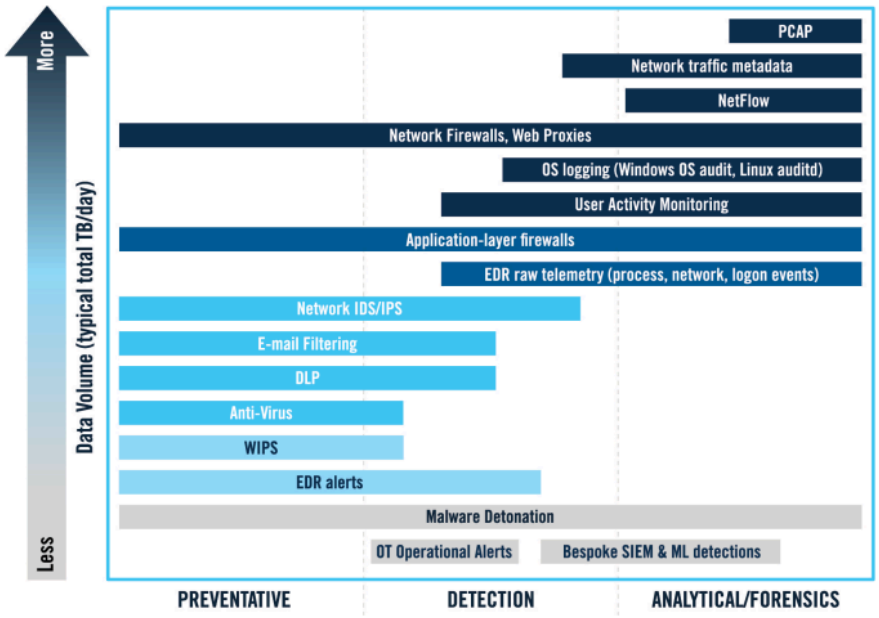

Figure 18. Data Source in Context of SOC Usage and Volume

13. In order to support forensics, what is the recommended data retention period (in months) to store logged EDR data? (Format: # of Months)

- 6

Table 15. Suggested Minimum Data Retention Time Frames

What	SOC triage	SOC forensics & investigations	External Support
EDR, network sensor alerts, and SIEM-correlated alerts	2 weeks	6 months	2+ years
NetFlow & traffic metadata logs	1 month	6 months	2+ years
Full-session PCAP	as needed*	as needed*	as needed*
System, network & application audit logs	2 weeks	6 months	2+ years
Emails	2 weeks	2 years	As needed

14. According to the threat intelligence concept the 'Pyramid of Pain', what indicators are Trivial, Easy, Challenging, Tough for adversaries to change? (Format: Indicator1, Indicator2, Indicator3, Indicator4)

- Hash Values, IP Addressed, Tools, TTPs

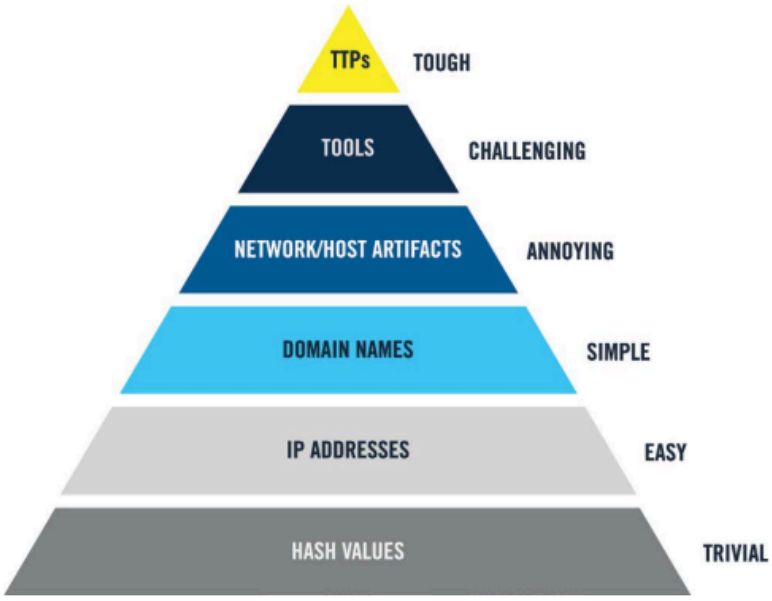

Figure 40. Pyramid of Pain [431]

15. Name of the Red Teaming approach to mimic the TTPs of an adversary? (Format: Approach Name)

- Adversary Emulation

11.2.3 Adversary Emulation

Advanced red teaming efforts sometimes include adversary emulation. Adversary emulation is an approach whereby a simulated attacker (such as a red team) mimics known threats and adversary-specific actions and behaviors. In contrast, more generalized red teaming utilizes any attack technique they are able to execute, unless specific rules of engagement limit their choices.

Is it red teaming or adversary emulation? If there is a need to distinguish between adversary emulation and other forms of red teaming, the following are distinct to adversary emulation:

- Is based on a real-world adversary known or likely to target your constituency
- Mimics the TTPs of this adversary
- Is not so generic that it could be multiple adversaries (in its entirely, many adversaries will have individual TTPs that overlap)